

Internal Audit Record

Organization: Cybersecurity Clinic Club

Standard: ISO 27001:2022

Audit Type: Internal Audit

Date: 12/11/25

Audit Objective

The main purpose of this internal audit was to assess and judge the conformity, effectiveness and correctness of the CyberSecurity Clinic's Information Security Management System (ISMS) against the requirements set out by the guidelines of ISO 27001:2022. This audit assessed whether confidentiality, integrity and availability are supported, technical controls are implemented and maintained by the policies documented and the procedures listed. This being an initial ISMS implementation with an academic clinic environment, there will be certain processes and controls still in the early stages of development and maturity. The heavy focus of this review is to focus on identifying structural and semantical gaps as well as establishing an improved, clear roadmap.

Audit Scope

The scope of the internal Audit included:

- ISMS governance and risk
- Risk Management and Planning Processes
- Access Control and selected technical controls within AWS environments
- Corrective action processes and Nonconformity

The audit went over all of the information assets and cloud resources managed under the Clinic's AWS organization. Some features, as they were out of the scope were excluded such as physical security and on premises infrastructure as this clinic was set to be entirely virtual.

Audit Criteria

The following criteria was used to conduct the audit:

- ISO 27001: 2022 clauses 4-10
- ISO 27001: 2022 Annex A controls (defined in the Statement of Applicability)
- Cybersecurity Policy made by the clinic

Audited Team

Top Management / Information Security Manager: Syed

Documentation Lead: Islam

Audit Lead: Bilal (read only access, independent of control implementation)

The internal audit was conducted by Professor Bon Sy.

Audit Activities

The following audit activities were performed:

- Review of ISMS policy documentation and scope definition
- Examination of risk management documentation and risk discussions
- Review of AWS security configurations and procedures as well as MFA and IAM enforcement
- Verification of restricted access to logging and monitoring mechanisms (CloudTrail)

Audit Findings Summary

The inter audit carried out resulted in identifiable opportunities for improvements (OFIs) and nonconformities (NCs) across technical and organizational controls as well. All of these NCs and OFIs were accepted by the auditee. These included:

- Human Resources and Organizational Controls (Clause 6)
- Access Controls and Technical Controls (Clause 8)
- Capacity Management (Control 8.6)
- Protection against Malware (8.7)
- Risk Management and Planning (Clause 6.1)
- Nonconformity and Corrective Action

Further Details Regarding Findings

The purpose of this section is to detail each OFI and NC including the specific vulnerability, threat sector and controls required to mitigate the task in accordance with ISO 27001: 2022.

Human Resource and Organizational Controls (Clause 6)

For this sector the identified vulnerability is the lack of formal screening, onboarding and documented security awareness training for Clinic participants and future employees. (Control 6.1 Screening)

The threat vector here is that insufficiently trained or unscreened participants may unintentionally mismanage sensitive data, mishandle or mismanage cloud resources or additionally misuse granted access due to lack of awareness. This may result in exposure to accidental data exposure to the wrong people or parties, integrity loss and even unauthorized changes within AWS environments. Additionally there were no pieces of formal evidence provided for security awareness, risks, risk assessment and their different levels.

The required fix or control for this is to implement an onboarding process with a documented screening process which includes compulsory security awareness training, acknowledgement of responsibilities and duties and role based access prerequisites prior to system access. This documentation will be kept in storage devices in s3 buckets.

Furthermore another nonconformity was identified due to the lack of formal documentation which must define the clinic participant's information security responsibilities. Prior to this a background check will be done after the interview process before a participant is officially employed. All of these documentations as well will be kept in s3 buckets.

Access Control and Technical Controls (Clause 8)

This is sighted as an OFI because although privileged access exists (**clause 8.2**) and is limited to certain personnel (Islam and Syed) there was insufficient evidence demonstrating formal approval, documentation and review of these privileges. These must be explicitly documented and reviewed to access and strengthen accountability as well as be approved and justified for access. Visible proof needs to be shown in AWS for access rights and switch roles (switch roles proves access rights as some roles can only view and not alter documents). Additionally, periodic access reviews must be carried out and evidence must be retained for future references.

Access to source code (**control 8.4**) was not applicable as confirmed by the SOA. Proprietary source code is not managed by the clinic. This determination was accepted and validated.

Considering secure authentication (**control 8.5**) the clinic demonstrated compliance through the enforcement of MFA (multi factor authentication) for IAM users. This control was considered effectively implemented.

With regards to Capacity Management (**Control 8.6**), the clinic shows that capacity management exists but lacks formally defined capacity objectives, monitored resources and objectives. Hindrances like service disruption, resource exhaustion and denial of service can all result due to poorly defined capacity limits which can affect the availability of learning

environments and audit evidence. Clearer definitions and monitoring objectives must be established to demonstrate effective capacity management and ensure continued availability.

Protection Against Malware (**Clause 8.7**) was not fully implemented due to lack of time constraints resulting from a late audit start. The threat vector includes compromised credentials, malware attacks, phishing scams and malicious activity which can possibly go undetected if this isn't fully attended to. Results can include data leaks, data exfiltration, hacking and overall integrity compromise.

In order to address this, GuardDuty will be implemented by the clinic to use as a threat detection service. Here CloudTrail logs will be examined in order to identify vulnerable or unauthorized access to IAM logins, suspicious behavior and things of that sort. This will ensure bold detection and future prevention of malicious activity and strengthen the ISMS credibility all while complying with ISO 27001:2022.

CloudTrail provides services that monitor resource usage, suspicious activities and things of like nature. Hence this nonconformity can be addressed in such a manner.

Risk Management and Planning (Clause 6.1)

Risks were not consistently defined in terms of Confidentiality, Integrity and Availability impact categories. These must be stated explicitly using categories to improve clarity and traceability. Due to inconsistent risk descriptors there may be a reduction in management's ability to prioritize treatment plans which can result in leaving high impact risks unattended and unaddressed. This can be fixed using document risks using CIA impact mapping to ensure clarity and traceability between risks and controls.

Under Information Security Risk Assessment (**Control 6.1.2**) there was an absence of a defined repeatable risk assessment methodology and quantifying risk including things like likelihood impact. To remediate this, there will be a structured risk assessment methodology put into place that will categorize the risks by levels. Defined criteria will be used to determine the overall risk level (low, medium, high). Risk assessments will be reviewed periodically and during management reviews.

Audit Conclusion

This concludes the internal audit for Cybersecurity Clinic and that they have established an initial ISMS framework aligned with ISO 27001: 2022, however it is in its early stages of maturity. There are several mandatory controls which require formalization, documentation and evidence to demonstrate effectiveness and conformity.

Audit Lead:

Name: Bilal Farooq

Disclaimer: This audit record includes sections drafted or refined using generative AI tools (Microsoft Copilot, OpenAI).